



SECURING AZURE ACTIVE DIRECTORY

@OWASP Stammtisch Frankfurt

Thomas Naunheim



THOMAS NAUNHEIM

Cloud Security Architect
@glueckkanja-gab AG

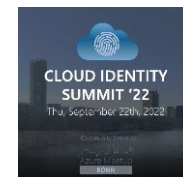
Koblenz, Germany



@Thomas_Live



cloud-architekt.net



AGENDA



IDENTITY SECURITY
POSTURE



CONDITIONAL ACCESS
AND TOKEN SECURITY



PRIVILEGED IDENTITY
AND ACCESS



WORKLOAD IDENTITIES
AND APP INTEGRATION

Underrated and critical aspect in #AzureAD security



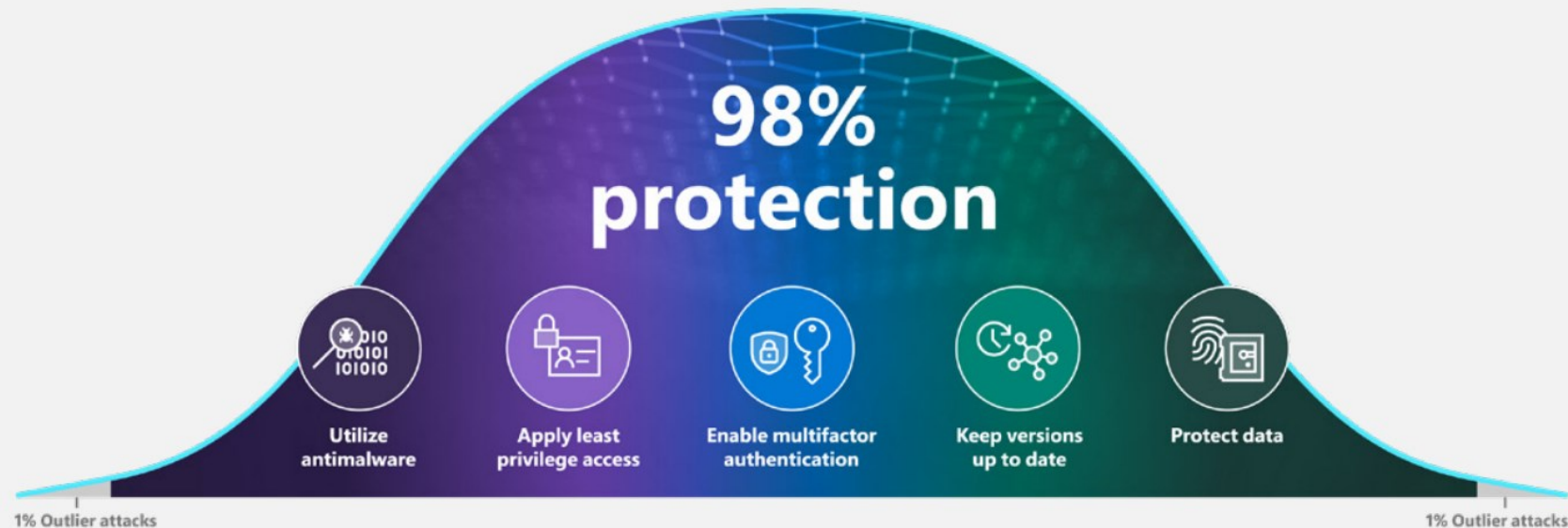


IDENTITY SECURITY POSTURE

Insights of modern identity attacks

The cybersecurity bell curve:

Basic security hygiene still protects against 98% of attacks



Security Default for Everyone

Home > Contoso - Properties

Contoso - Properties

Azure Active Directory

Search (Ctrl+/)

Save Discard

Overview

Getting started

Manage

- Users
- Groups
- Organizational relationships
- Roles and administrators
- Enterprise applications
- Devices
- App registrations
- Identity Governance
- Application proxy
- Licenses
- Azure AD Connect
- Custom domain names
- Mobility (MDM and MAM)
- Password reset
- Company branding
- User settings
- Properties**
- Notifications settings

Directory properties

Name *

Contoso

Country or region

United States

Location

United States datacenters

Notification language

English

Directory ID

69997834-fa40-45da-bad8-382c3bdc66c3

Technical contact

technical@contoso.com

Global privacy contact

privacy@contoso.com

Privacy statement URL

Access management for Azure resources

balas@contoso.com Bala Sandhu (balas@contoso.com) can manage access to management groups in this directory. [Learn more](#)

Yes No

Manage Security defaults

Enable Security defaults

Security defaults is a set of basic identity security mechanisms recommended by Microsoft. When enabled, these recommendations will be automatically enforced in your organization. Administrators and users will be better protected from common identity related attacks. [Learn more](#)

Enable Security defaults

Yes No

Save

- Replacement of “Baseline”-Policies

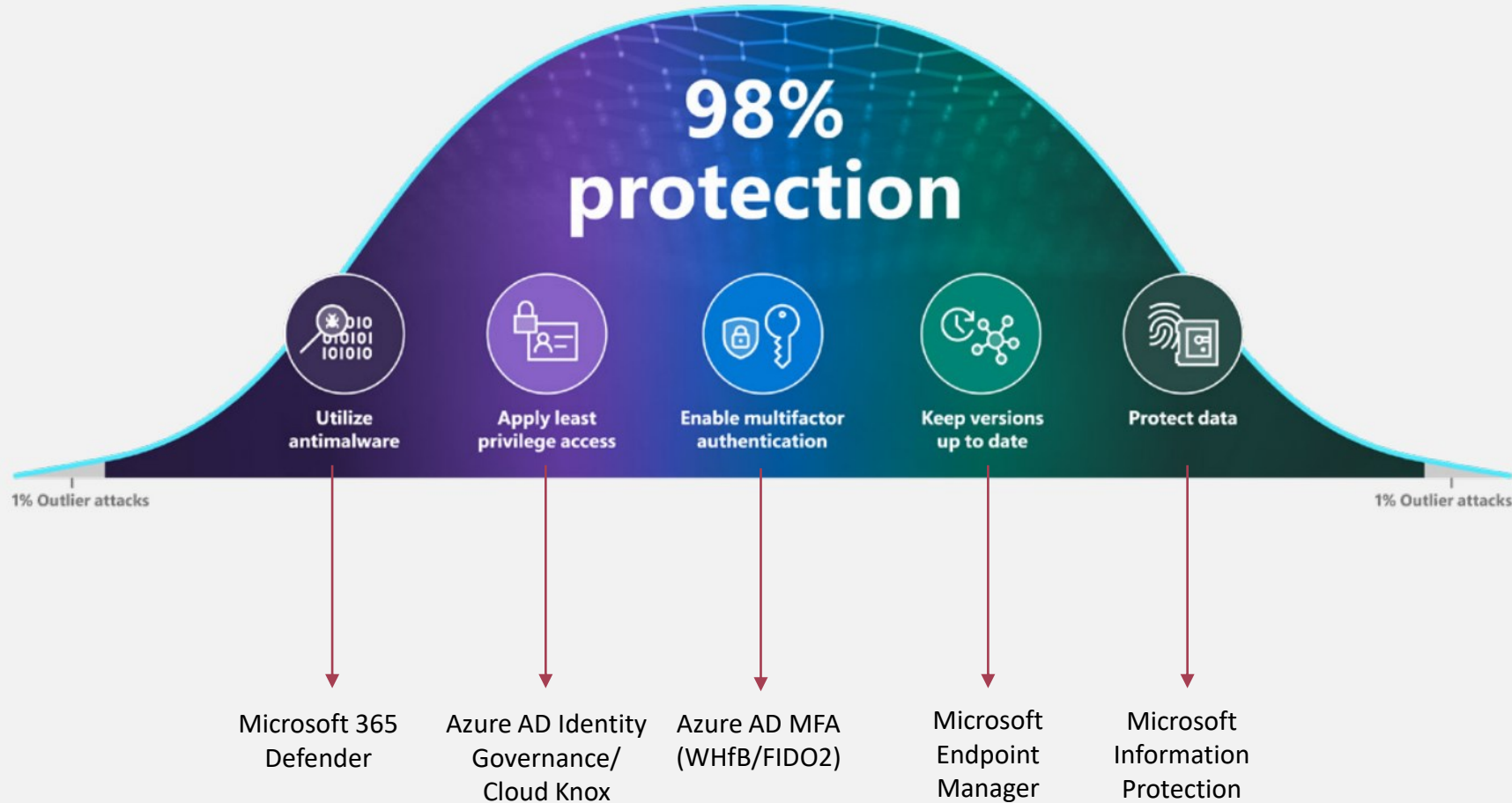
Create your own policies and target specific conditions like Cloud apps, Sign-in risk, and Device platforms with Azure AD Premium [→](#)

POLICY NAME	ENABLED	
Baseline policy: Require MFA for admins	✓	...
Baseline policy: End user protection (Preview)		...
Baseline policy: Block legacy authentication (Preview)		...
Baseline policy: Require MFA for Service Management (Preview)		...

- No extra costs or AAD license required (available for all tenant, enabled by default)
- Minimal security baseline by enforced policies
- *“Security defaults provide secure default settings that (Microsoft) manages on behalf of organizations to keep customers safe **until they are ready to manage their own identity security story.**”*

Quote from Alex Weinert's Blog post

Insights of modern identity attacks



Azure AD Identity Secure Score

Overview Improvement actions History Metrics & trends

Microsoft Secure Score is a representation of your organization's security posture, and your opportunity to improve it.

Applied filters:

Filter

Your secure score

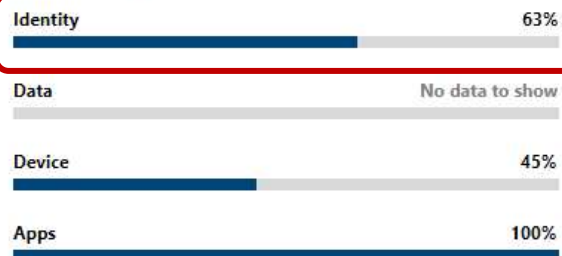
Include

Secure Score: 46%

379/820 points achieved



Breakdown points by: Category



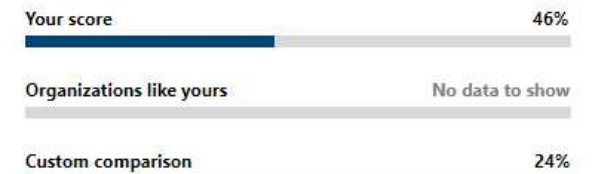
Actions to review



Top improvement actions

Improvement action	Score impact	Status	Category
Turn on Microsoft Defender Application Guard managed mode	+1.1%	☒ Risk accepted	Device
Block credential stealing from the Windows local security authorit...	+1.1%	☐ To address	Device
Use advanced protection against ransomware	+1.1%	☐ To address	Device
Block execution of potentially obfuscated scripts	+1.1%	☐ To address	Device
Block Office applications from injecting code into other processes	+1.1%	☐ To address	Device
Block executable content from email client and webmail	+1.1%	☐ To address	Device
Encrypt all BitLocker-supported drives	+1.1%	☐ To address	Device

Comparison

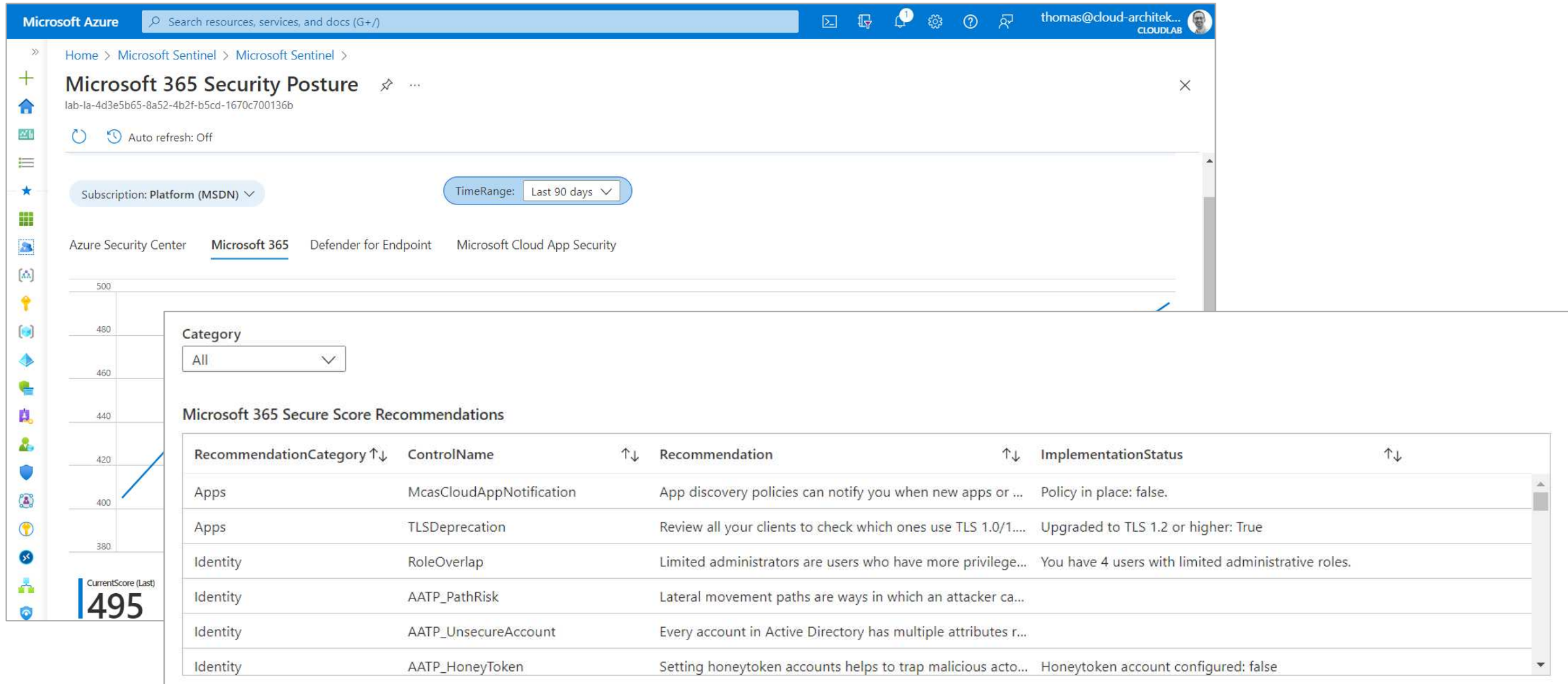


Manage comparisons

Resources

- [Read about Secure Score capabilities](#)
Learn about the improvement actions and how to improve your score.
- [Do more with the Secure Score API](#)
Learn how to use the API to take your monitoring and reporting even further.

Operationalization of Identity Secure Score



Azure Security Benchmark (V3)

🛡️ Please take time to answer a quick survey, [click here](#).

Control Areas

🔍 Search

- ☒ Section ↑↓
- ☐ Assessment
- ☐ Network Security (NS)
- ☒ Identity Management (IM)
- ☒ Privileged Access (PA)

🔍 Single vs Multi-Factor Authentication by Account

🔍 Search

UserPrincipalName	↑↓ AuthenticationRequirement	↑↓ AppDisplayName	↑↓ count_	↑↓
cloudadmin@c4a8ando.net	✅ multiFactorAuthentication	Azure Portal	3177	
thomas@cloud-architekt.net	❌ singleFactorAuthentication	Microsoft App Access Panel	2600	
thomas@cloud-architekt.net	✅ multiFactorAuthentication	Microsoft App Access Panel	2360	
thomas@cloud-architekt.net	❌ singleFactorAuthentication	WindowsDefenderATP	747	

Azure Security Benchmark

Welcome to the Azure Security Benchmark workbook. This workbook is designed to enable Cloud Architects, Security Engineers, and Governance Risk Compliance Professionals to gain situational awareness for cloud security posture and hardening. Benchmark recommendations provide a starting point for selecting specific security configuration settings and facilitate risk reduction. The Azure Security Benchmark includes a collection of high-impact security recommendations for improving posture. For more information, see the [Azure Security Benchmark](#).

IM-5: Monitor and Alert on Account Anomalies

Azure Security Center - Regulatory Compliance - Azure Security Benchmark

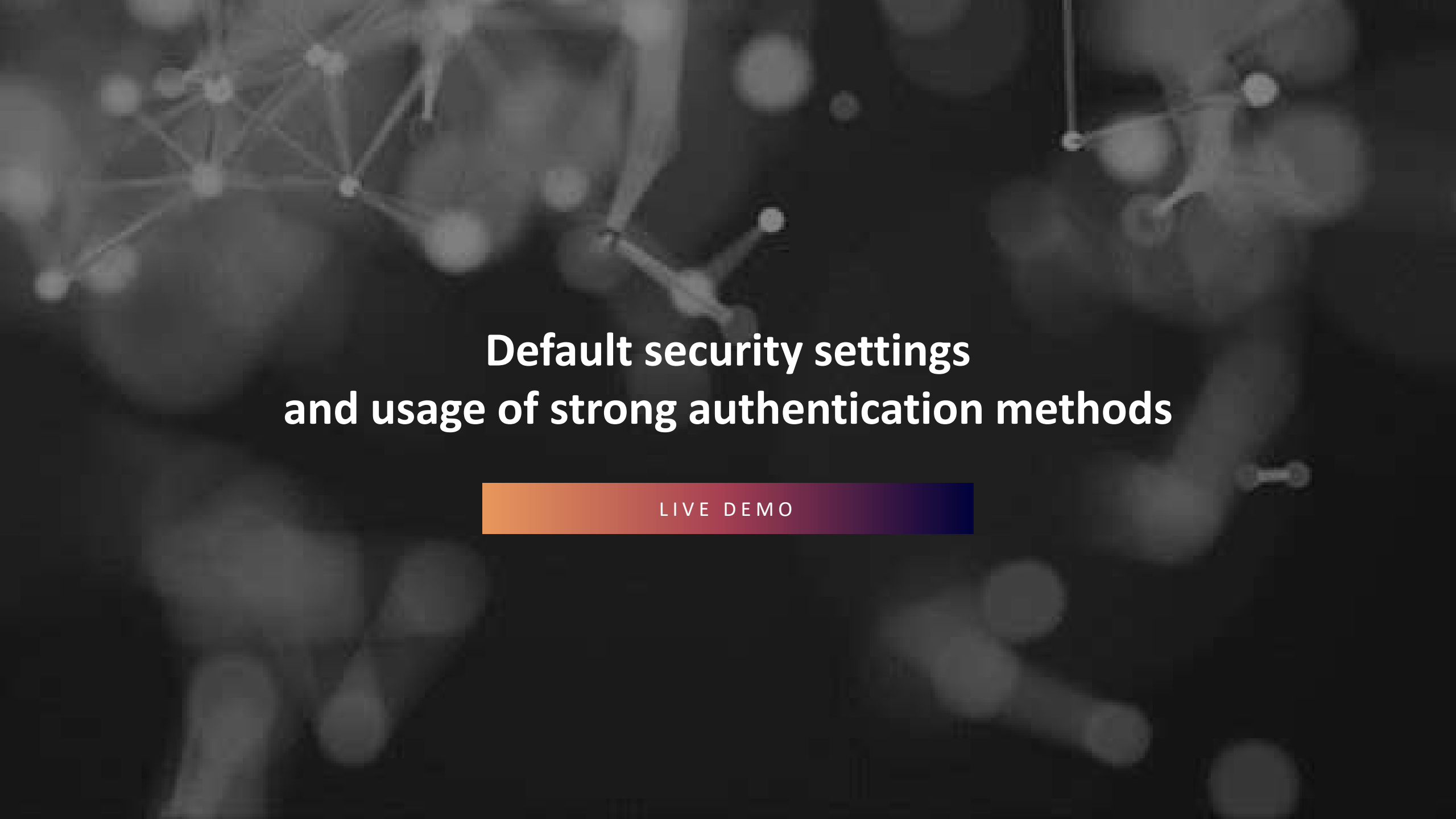
Recommended Logs

◆ BehaviorAnalytics ◆ SecurityAlert 🟢 Azure Sentinel

🔍 User Anomalies

🔍 Search

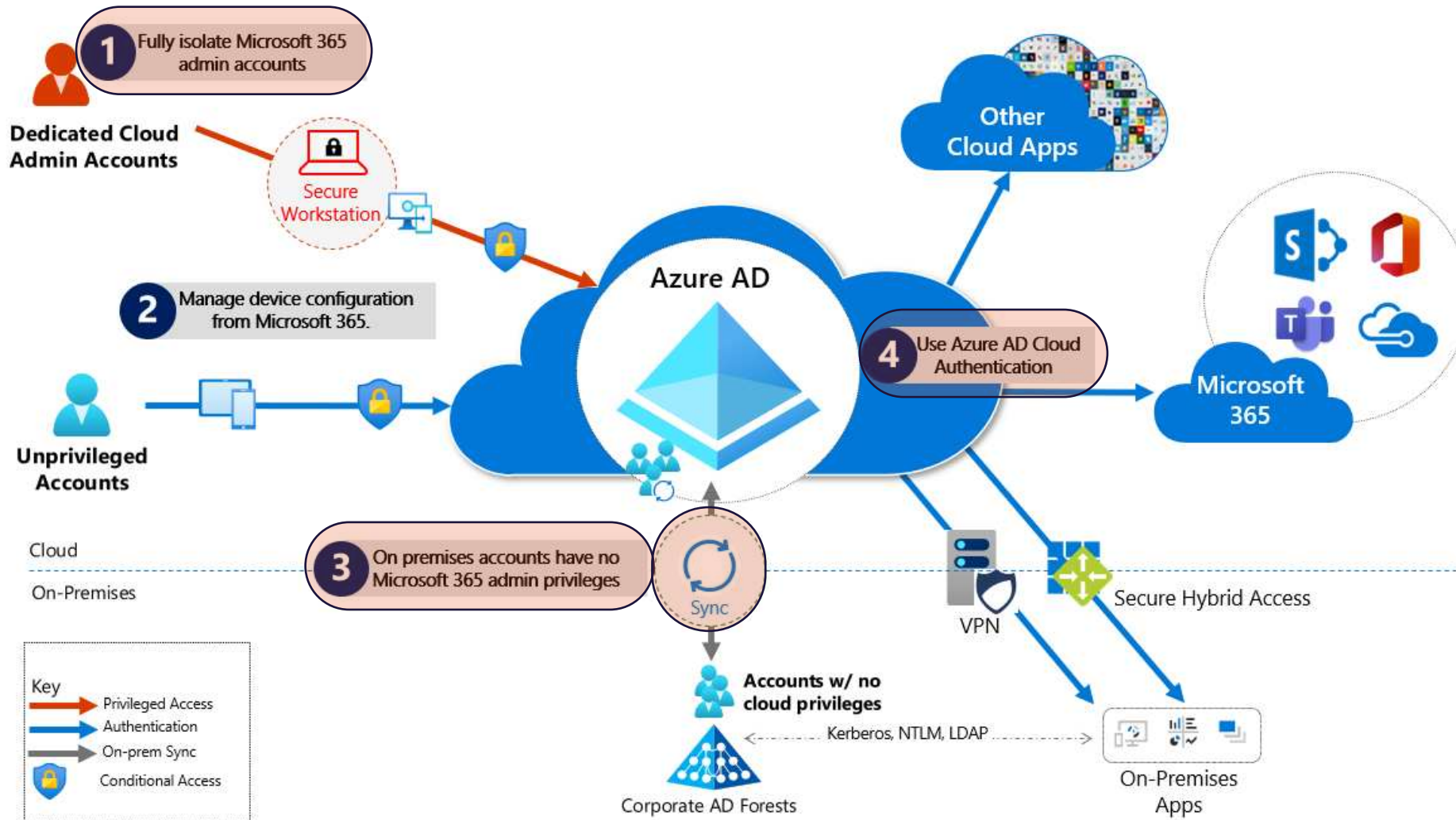
UserPrincipalName	↑↓ Uncomm...↑↓	Uncomm...↑↓	FirstTi
thomas.naunheim@outlook.com	26	26	
Sync_ANDS1_bbcab499138c@c4a8ando.onmicrosoft.com	23	44	



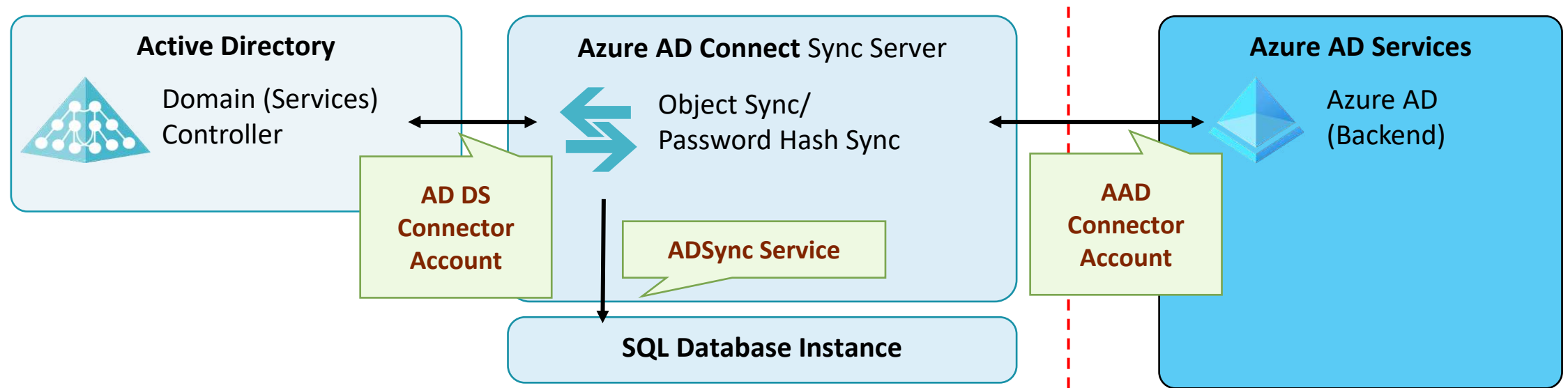
Default security settings and usage of strong authentication methods

LIVE DEMO

Attack surface in hybrid identity environments



Attack surface by hybrid identity sync



Privilege Escalation from AAD Connect to Azure AD

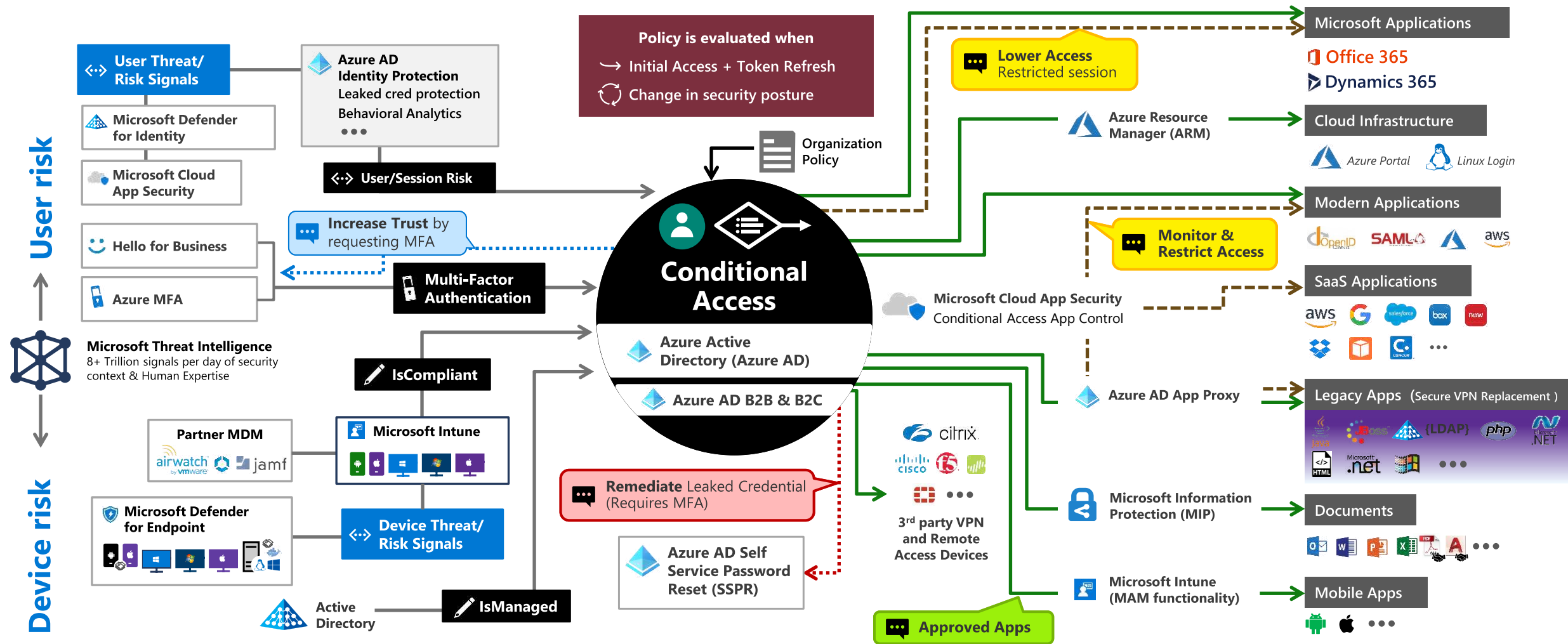
LIVE DEMO



CONDITIONAL ACCESS AND TOKEN SECURITY

Conditional Access Overview

Image Source: [Microsoft](#) ("Zero Trust Definition and Models")



Signal
to make an informed decision



Decision
based on organizational policy



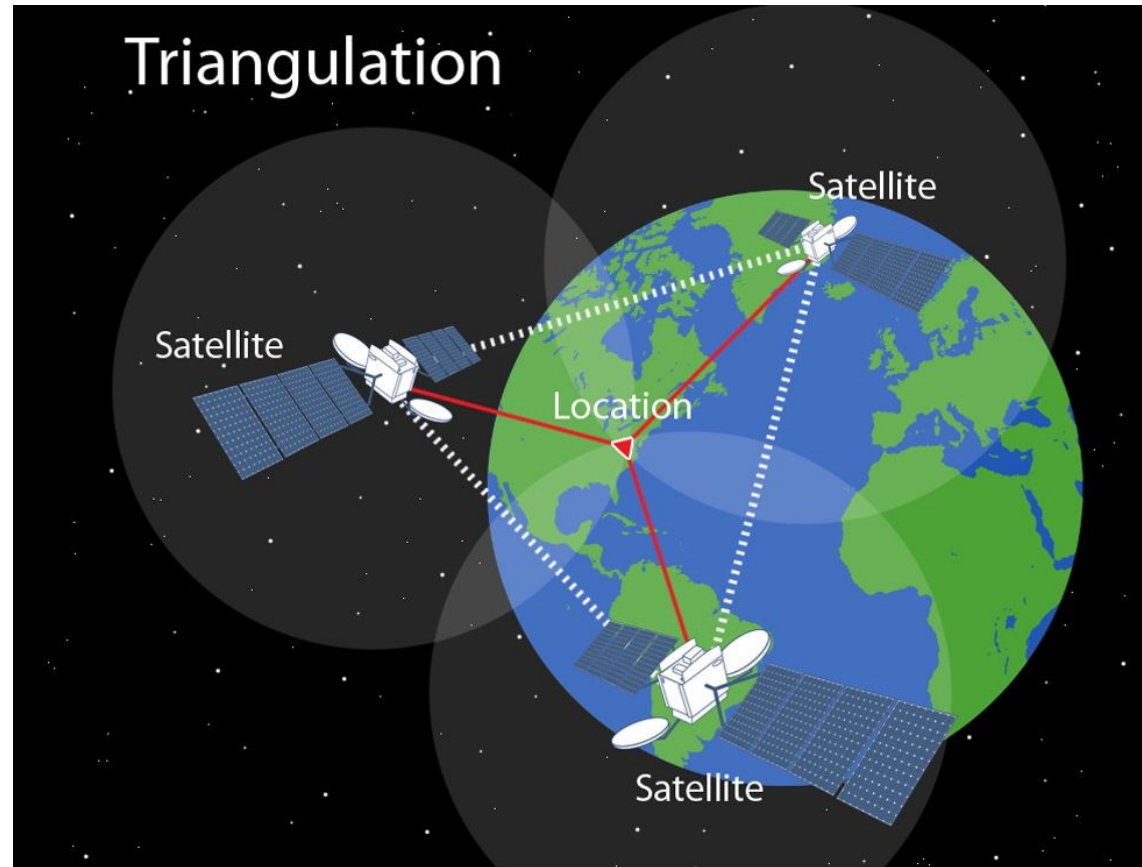
Enforcement
of policy across resources

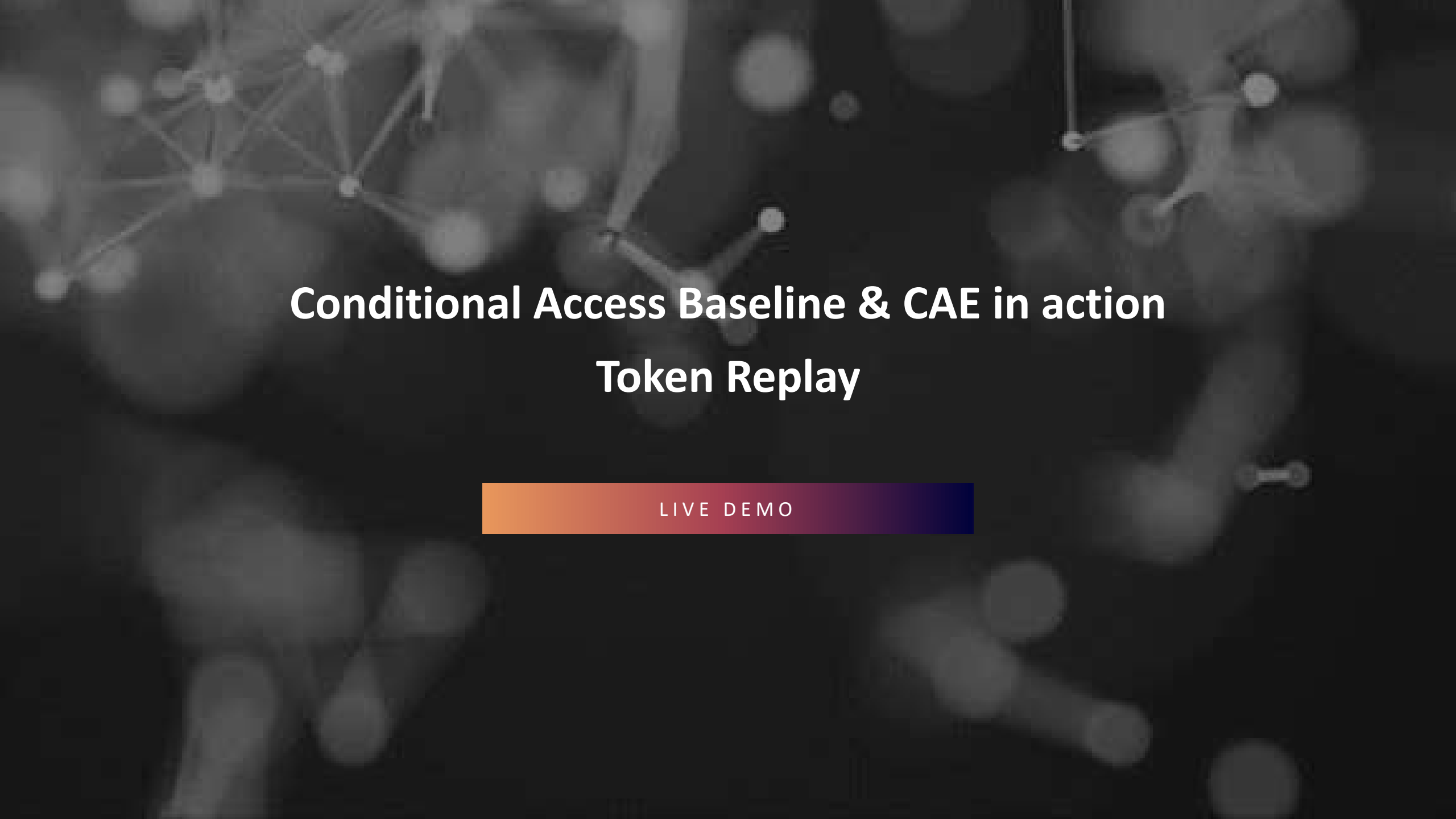
Strong baseline for Conditional Access



Ensure to protect every user and every app by minimal but strong baseline!

Strong claims & efficient controls in Conditional Access





Conditional Access Baseline & CAE in action

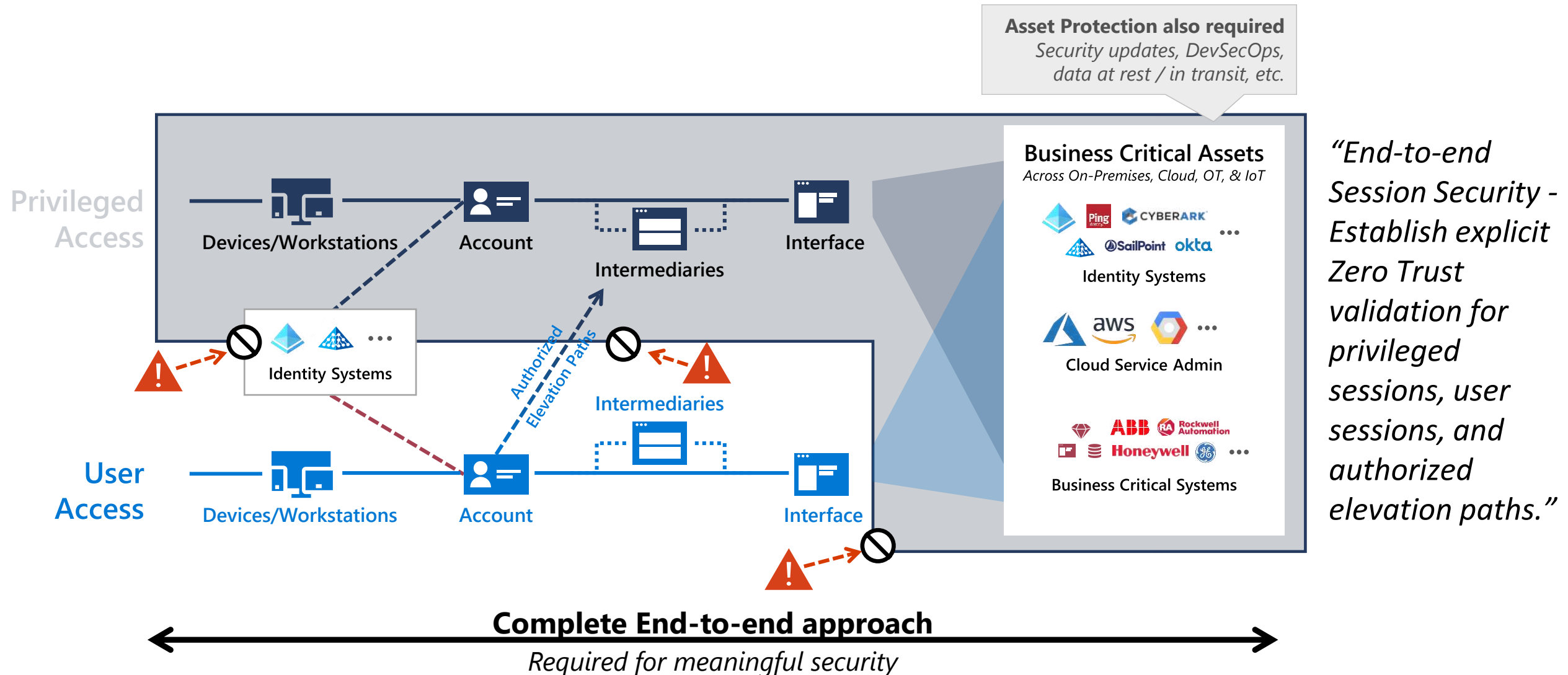
Token Replay

LIVE DEMO



PRIVILEGED IDENTITY AND ACCESS

Authorized privileged and elevated paths



Foundation of Privileged Access



Granular Task
Scoped Access
(Just Enough)

CloudKnox



Just in Time
Access



Privileged
Admin
Workflow

Privileged Identity Management (PIM)



Access Request
and Review

Identity Governance

Administrative Tier Model

„To mitigate risk of identity compromise, or bad actors, implement **tiered administration** and ensure that you **follow principles of least privilege for Azure AD Administrator Roles.**“

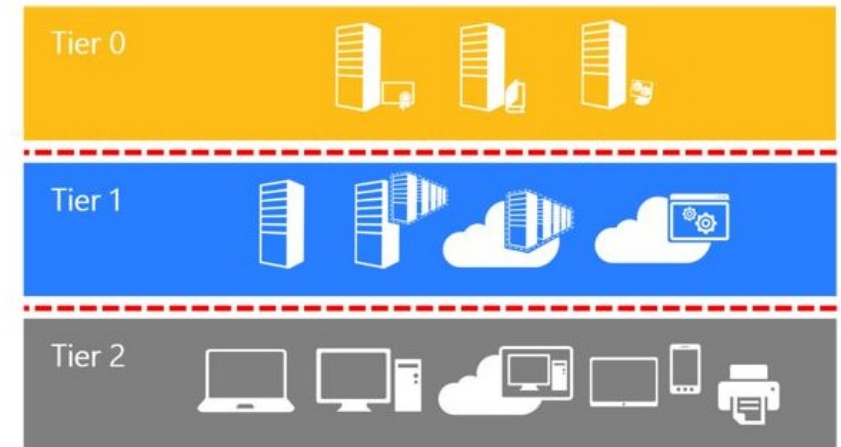
Source: „Securing Azure Environments with Azure AD (Architecture and Design Guide)“, Page 8

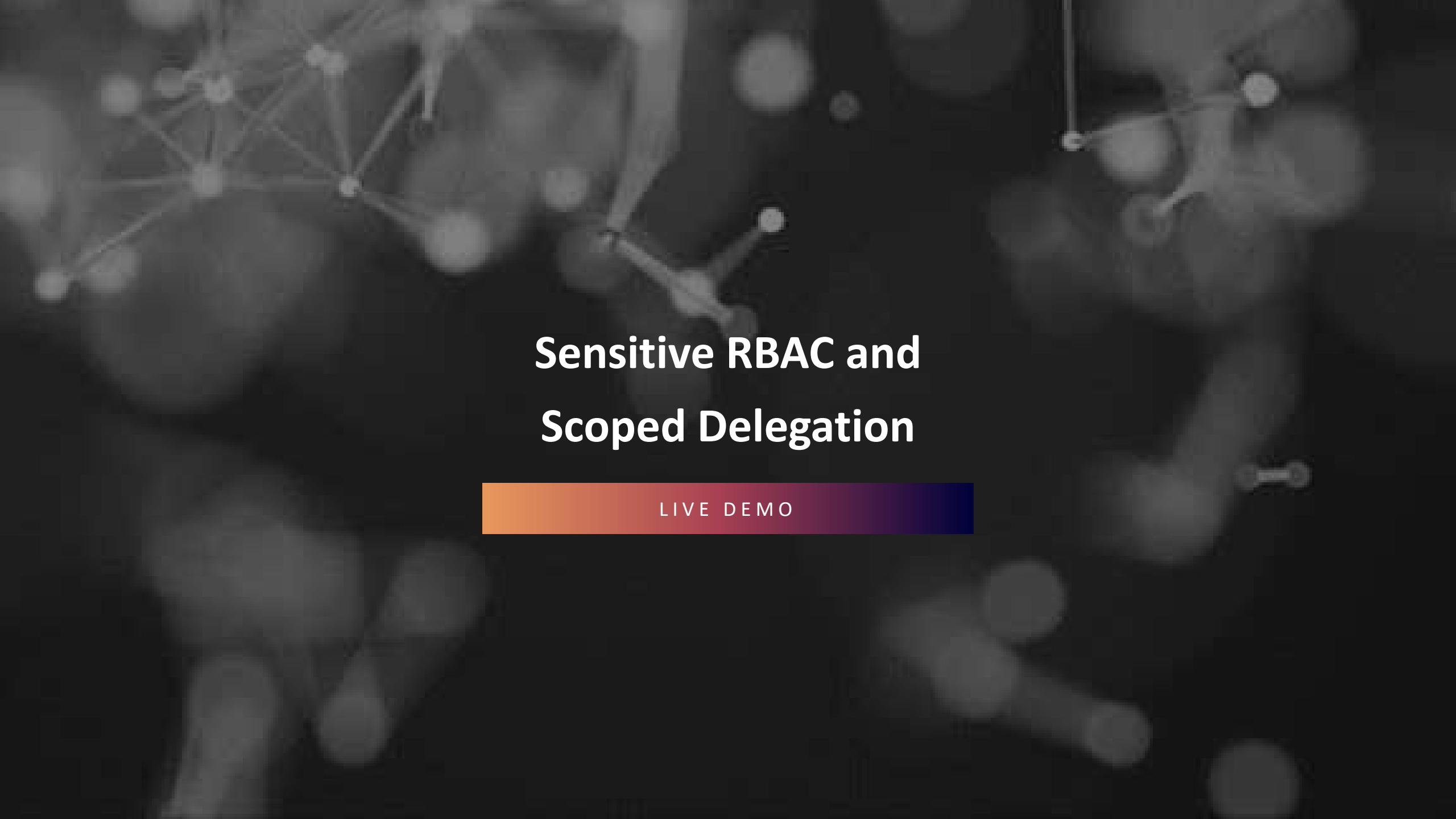
Active Directory administrative tier model

02/14/2019 • 33 minutes to read •  +6

Applies To: Windows Server

The purpose of this tier model is to protect identity systems using a set of buffer zones between full control of the Environment (Tier 0) and the high risk workstation assets that attackers frequently compromise.





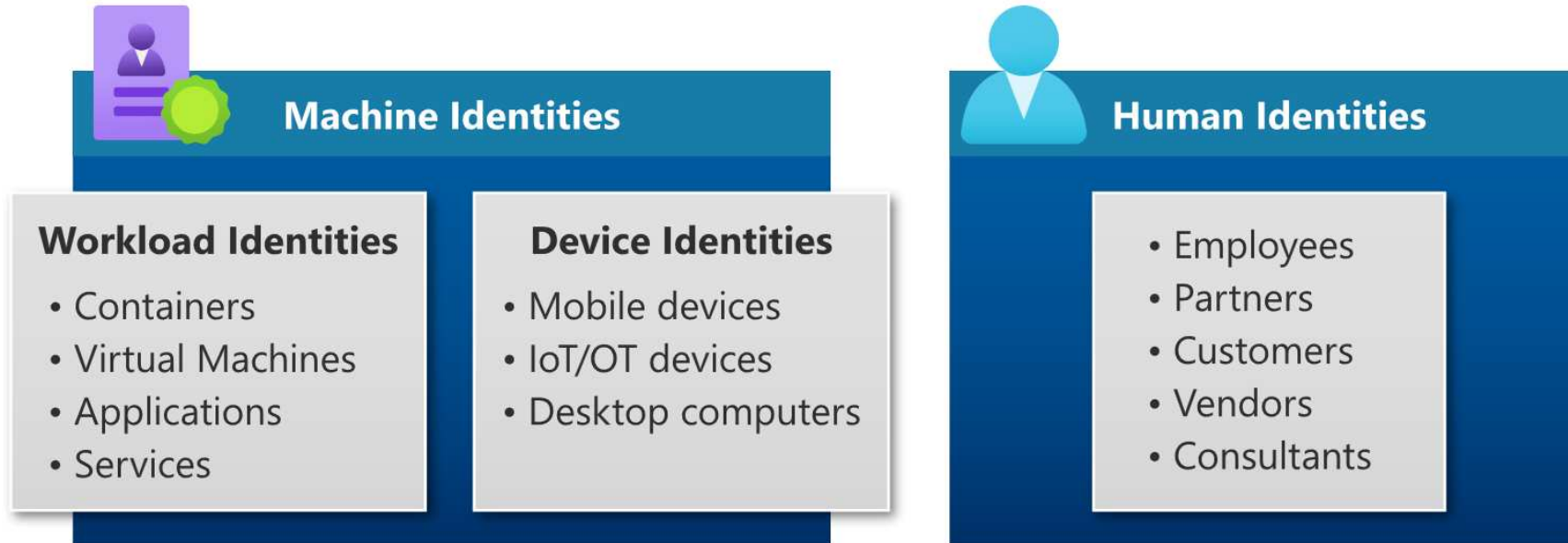
Sensitive RBAC and Scoped Delegation

LIVE DEMO



APP INTEGRATION AND WORKLOAD IDENTITIES

Types of identities



Types of workload identities

Criteria	Service Principal (Key- or Certificate)	Managed Identity (System- or User Assigned)	Service Principal (Federated Credentials)
Supported use cases	No limitation	Limited to supported Azure Resources	Limited to supported Workload Identity Federation Provider
Security boundary	Single- or multi-tenant	Single-Tenant*	Single- or multi-tenant*

Types of workload identities

Criteria	Service Principal (Key- or Certificate)	Managed Identity (System- or User Assigned)	Service Principal (Federated Credentials)
Supported use cases	No limitation	Limited to supported Azure Resources	Limited to supported Workload Identity Federation Provider
Security boundary	Single- or multi-tenant	Single-Tenant*	Single- or multi-tenant*
Lifecycle management	Managed by Admin	Managed by Azure (System-) or Admin (User-Assigned)	Managed by Admin
Prevention of privilege escalation	Service Principal and assigned permissions (Roles, Owner)	Azure resource with assignment to identity	Service Principal and assigned permissions (Roles, Owner)
	Secure storing of credentials	Azure RBAC to resource object	Security of the Federated IdP and workload
	Detection of unusual creation of credentials (MDA, Sentinel)		

Types of workload identities

Criteria	Service Principal (Key- or Certificate)	Managed Identity (System- or User Assigned)	Service Principal (Federated Credentials)
Supported use cases	No limitation	Limited to supported Azure Resources	Limited to supported Workload Identity Federation Provider
Security boundary	Single- or multi-tenant	Single-Tenant*	Single- or multi-tenant*
Lifecycle management	Managed by Admin	Managed by Azure (System-) or Admin (User-Assigned)	Managed by Admin
Prevention of privilege escalation	Service Principal and assigned permissions (Roles, Owner) Secure storing of credentials Detection of unusual creation of credentials (MDA, Sentinel)	Azure resource and delegation to manage them	Service Principal and assigned permissions (Roles, Owner) Security of the Federated IdP
Restrict token acquisition	Conditional Access (risk-based conditions on leaked cred. or suspicious sign-ins)	Not available	Conditional Access (risk-based conditions on suspicious sign-ins), Entity (subject identifier)
Exfiltration/Token replay	Active monitoring required (incl. inventory and usage history) IPC risk detections available		IPC risk detections available

Security of App Integration

Microsoft Azure Search resources, services, and docs (G+/)

Home > CloudLab > BusinessApp-Auth-WebAPI

BusinessApp-Auth-WebAPI | Integration assistant

Search (Ctrl+/) Refresh Got feedback?

Overview Quickstart Integration assistant

Manage

- Branding & properties
- Authentication
- Certificates & secrets
- Token configuration
- API permissions
- Expose an API
- App roles
- Owners
- Roles and administrators
- Manifest

Support + Troubleshooting

- Troubleshooting
- New support request

Here's the integration assistant for BusinessApp-Auth-WebAPI

Application type : Desktop App, Web API [Edit](#)

Calls APIs : Yes

Summary Develop Test Release Monitor

Recommended configurations

Item	Status
Configure a redirect URI for a desktop app by adding a platform.	Action required
Configure API permissions.	Action required
Configure a valid credential.	Action required
Configure a unique Application ID URI.	Action required
If expecting API requests on behalf of users, define scopes your API exposes.	Action required
If expecting API requests on behalf of apps directly, define app roles.	Action required
Assign users that should be able to view and edit this application registration as owners.	Complete

Discouraged configurations

Item	Status
If you are using the authorization code flow, disable the implicit grant settings.	Complete

More details:

- [Azure AD application registration security best practices](#)
- [Microsoft identity platform best practices and recommendations](#)

App registration and consent grant



① testuser@fourthcoffeetest.onmicrosoft.com

② Permissions requested

③ Best Practices Demo ④
 microsoftidentity.dev ⑤ ⑥

This application is not published by Microsoft or your organization. ⑦

This app would like to:

- ✓ Maintain access to data you have given it access to
- ^ Sign you in and read your profile

⑨ { Allows you to sign in to the app with your organizational account and let the app read your profile. It also allows the app to read basic company information. } ⑧
 { This is a permission requested to access your data in Fourth Coffee. }

Accepting these permissions means that you allow this app to use your data as specified in their [terms of service](#) and [privacy statement](#). You can change these permissions at <https://myapps.microsoft.com>. ⑩

Only accept if you trust the publisher and if you selected this app from a store or website you trust. Ask your admin if you're not sure. Microsoft is not involved in licensing this app to you. [Hide details](#) ⑪

Does this app look suspicious? [Report it here](#) ⑫

Cancel

Accept

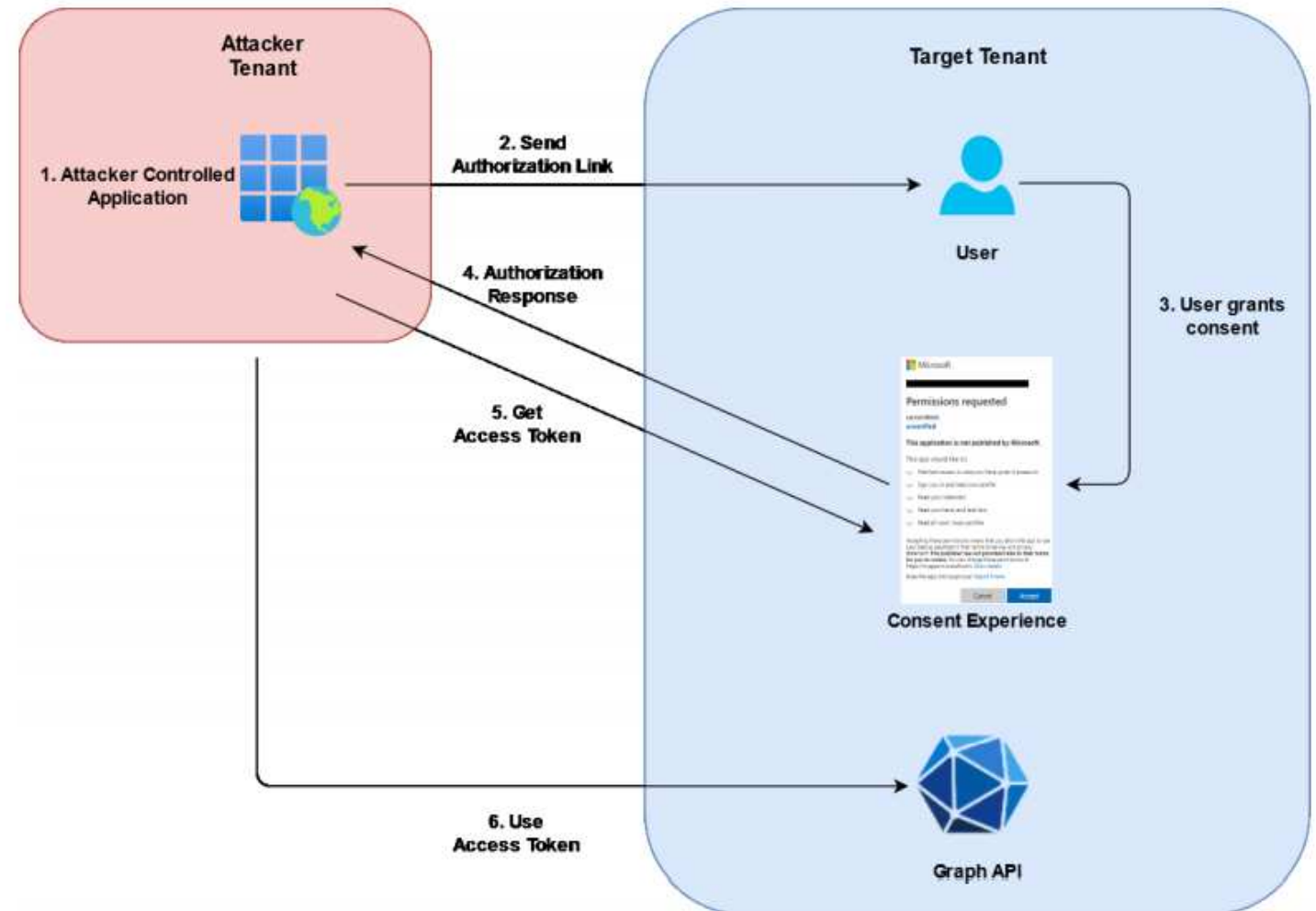


Image source: *Introduction To 365-Stealer by Altered Security*



Illicit Consent Grant Attack

Auditing and Monitoring of Service Principals

LIVE DEMO

AZURE AD ATTACK & DEFENSE PLAYBOOK

written by Sami Lamppu, Joosua Santasalo and Thomas Naunheim



SECURING AZURE AD CALL FOR ACTIONS



Implement an active identity security posture management and review of (default) settings
Use cloud and phishing resistant authentication methods (PHS + FIDO2/WHfB)
Protect your Azure AD connect as Tier0 asset (of both worlds) incl. MDE and monitoring



Use clear and enriched signals as conditions in your Conditional Access Policies
Monitor and review your efficiency and coverage of policy configuration
Enforce strong controls for user access (device compliance, always MFA)



Enforce authorization paths for privileged access (incl. device filters for access from SAW/PAW only)
Consider access paths by directory-level roles, partner access delegation or other RBAC systems
Implement least-privileged RBAC design (Tiered Admin Model) with Identity Governance processes



Disable user consent for (risky) permissions and implement admin approval flow
Replace owner permissions by scoped Azure AD roles, restrict access to sensitive delegated permissions
Implement a lifecycle model, inventory and active monitoring with IR for workload identities

THANK YOU



@Thomas_Live



Thomas@Naunheim.net

www.cloud-architekt.net